

CSC215 Lab2 – Port Scan

Total: 100pt

due date see Blackboard

@Copyright Dr. Xiang Fu. All Rights Reserved.

What to turn in: Upload CSC215Lab2.docx to Canvas assignment 2. Please type your solution and take screenshots when asked. To take a screenshot, click into the background of your host OS, and then hit the PrtSc key.

1. DNS Exploration [50pt]

The goal of this practice is to enrich your experiences in Linux system configuration and trouble shooting. In this lab, you will need to *fix a partially working DNS* (domain name system) of the 169.254.0.0/16 network segment.

Lab Setup: Please restore the “INITIAL” snapshot of all your OS images before proceeding.

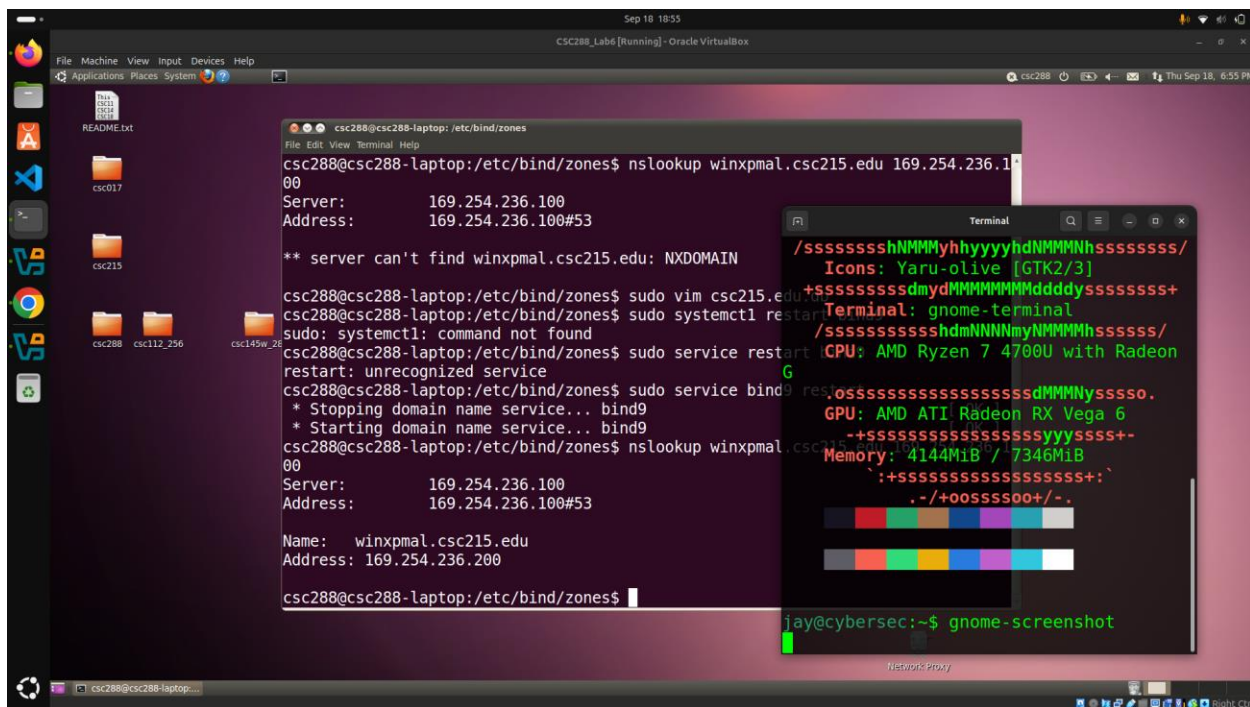
Task 1. [10pt] Exploration of 169.254.0.0/16 (domain csc215.edu). Use the following DNS exploration tools (Dnsdict6, Dnsmap, Fierce, and ReverseRaider) provided by Backtrack5 (**BackTrack-> Information Gathering -> Network Analysis -> DNS Analysis Tools**), and compare their performance. Fill out the following table [hint: there should be at least **4 names** (including all aliases) in the domain, but some dictionary-attack based tools might miss some names. *Some might be reporting NOTHING!*] (**hint: you should check the database file of bind9 to find all server names for column 1 of the following table**)

Name	IP	Enter “Y” if the (sub)domain/name discovered by the following tools			
		Dnsdict6	Dnsmap	Fierce	ReverseRaider
backtrack.csc215.edu	169.254.236.111	N	N	Y	Y
ns	169.254.236.100	Y	Y	Y	Y
ubuntu	ns	Y	N	Y	Y
www	ubuntu	Y	Y	Y	Y

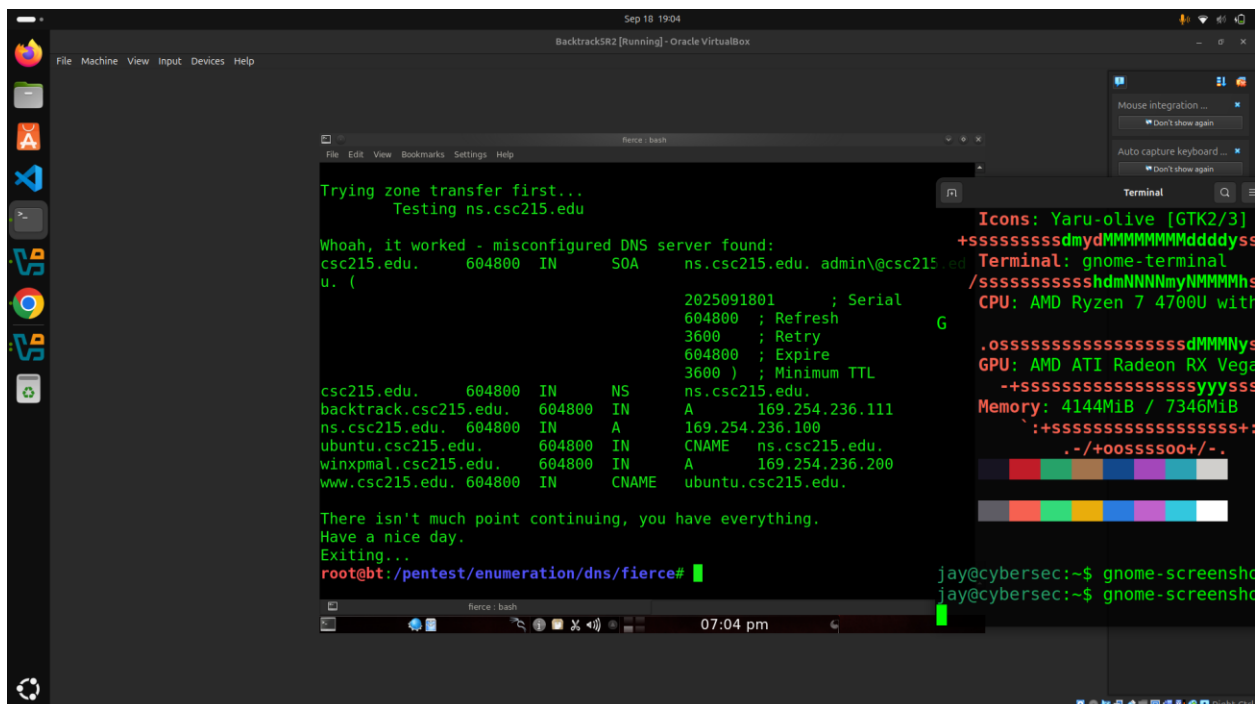
Task 2. [10pt] Explain why Fierce has better performance in this case.

Fierce has better performance because it uses zone transfer instead of bruteforcing.

Task 3. [20pt] Read the DNS set up tutorial “How to set up DNS in Ubuntu” at <http://ulyssesonline.com/2007/11/07/how-to-setup-a-dns-server-in-ubuntu/>. Add a new name record “winxpmal” to the DNS registry, map it to IP “169.254.236.200”. To prove your success, paste the screenshot of “nslookup winxpmal.csc215.edu 169.254.236.100” below. Note that your domain server (of M169.254.0.0/16 network) is located at 169.254.236.100 (Linux Ubuntu).



Task 4. [10pt] It is often regarded as a safe practice to disable DNS Zone Transfer. Reset and restart the bind9 service (without rebooting Ubuntu, i.e., you just need to restart the bind9 service) and prove that your setting is successful by pasting the record of Fierce below.



2. Network Scanning [30pt]

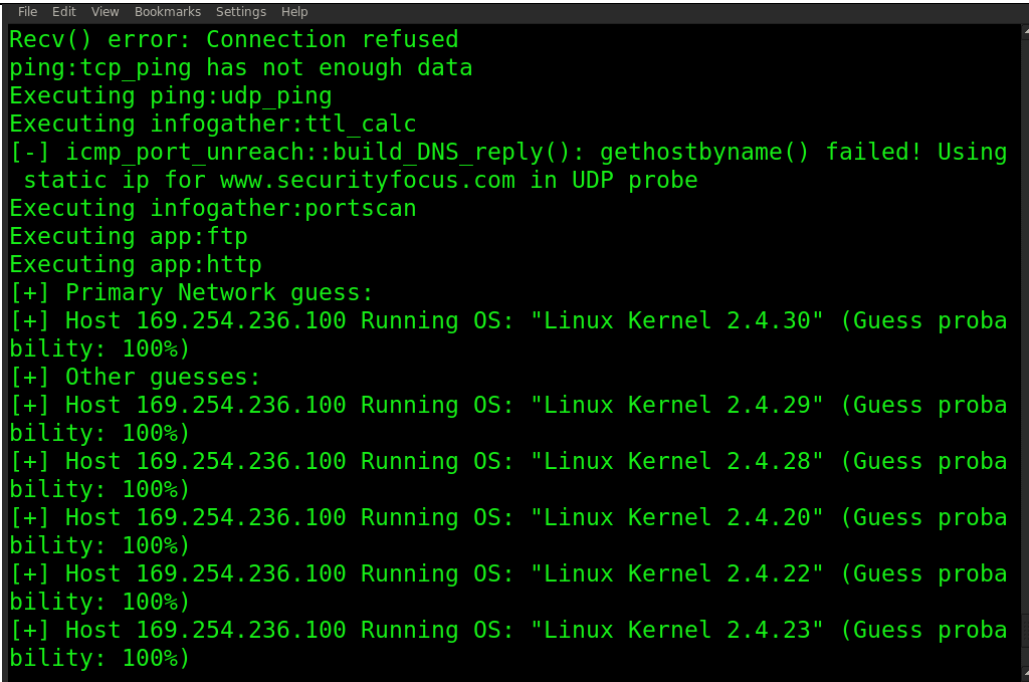
Task 1 [10pt] Discover all live hosts in 169.254.236.0/24, using the following tools available in the “**Identify Live Hosts**” category of Backtrack 5 (Please have both BT5 and Ubuntu image started. If you use Adams 204 computers, you can also start WinXP image **but XP image is not required for completing this question**). Compare their performance. Before the experiment, **reset the bind9 service to allow zone transfer**.

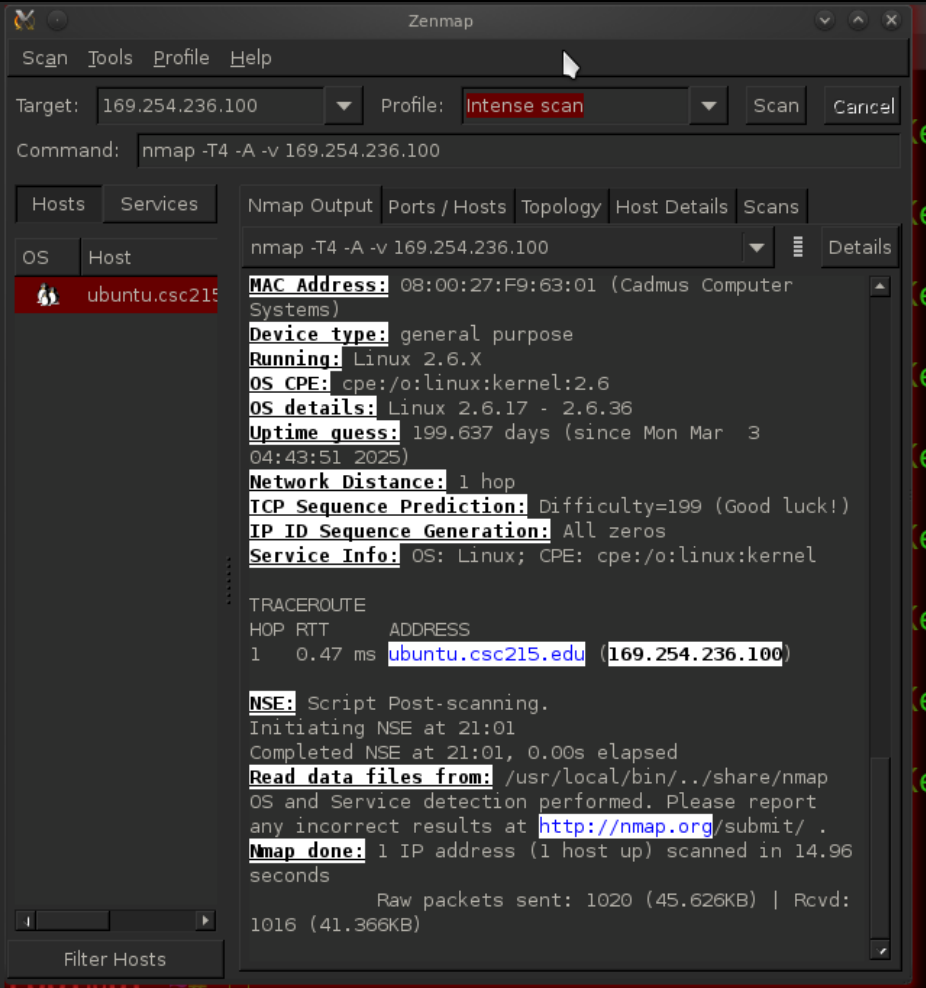
IP	Enter “Y” if the IP is discovered			
	alive6	netdiscover	nmap	netifera
169.254.236.111	N	N	Y	Y
169.254.236.100	N	Y	Y	Y
169.254.236.200	N	N	N	N

Task 2 [10pt] Find all open ports on 169.254.236.100 using nmap. Log into 169.254.236.100, and find out the processes that listen on these ports (note: don’t list those internal ports that are not available to public). [hint: check the frequently used Linux commands in Lecture 1, i.e., the sudo lsof command]

Port	Absolute Path of Process Listening to the Port
80	/usr/sbin/apache2
22	/etc/ssh
23	/usr/share/doc/telnet
53	/usr/sbin/named
80	/usr/lib/apt/methods/http
443	/usr/lib/apt/methods/https

Task 3 [10 pt] Identify the OS version of 169.254.236.100 using the following tools.

Tool	Version of OS
Xprobe2	 <pre>File Edit View Bookmarks Settings Help Recv() error: Connection refused ping:tcp_ping has not enough data Executing ping:udp_ping Executing infogather:ttl_calc [-] icmp_port_unreach::build_DNS_reply(): gethostbyname() failed! Using static ip for www.securityfocus.com in UDP probe Executing infogather:portscan Executing app:ftp Executing app:http [+] Primary Network guess: [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.30" (Guess proba bility: 100%) [+] Other guesses: [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.29" (Guess proba bility: 100%) [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.28" (Guess proba bility: 100%) [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.20" (Guess proba bility: 100%) [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.22" (Guess proba bility: 100%) [+] Host 169.254.236.100 Running OS: "Linux Kernel 2.4.23" (Guess proba bility: 100%)</pre>

Nmap	<pre>Starting Nmap 5.61TEST4 (http://nmap.org) at 2025-09-18 20:38 EDT Nmap scan report for ubuntu.csc215.edu (169.254.236.100) Host is up (0.00042s latency). Not shown: 993 closed ports PORT STATE SERVICE 22/tcp open ssh 23/tcp open telnet 53/tcp open domain 80/tcp open http 443/tcp open https 8651/tcp open unknown 8652/tcp open unknown MAC Address: 08:00:27:F9:63:01 (Cadmus Computer Systems) Device type: general purpose Running: Linux 2.6.X OS CPE: cpe:/o:linux:kernel:2.6 OS details: Linux 2.6.17 - 2.6.36 Network Distance: 1 hop OS detection performed. Please report any incorrect results at http://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 2.82 seconds root@bt:~#</pre>
Zenmap	

3. Ethics of Penetration Testing [20pt]

Consider the following scenario: a penetration tester A discovers a severe vulnerability in a proprietary server application, owned/developed by some company B. A owns a license of the software, which, forbids reverse engineering of the binary code of the software. However, A finds the vulnerability via random testing (i.e., sending large amount of random data to the server). A notifies B of the vulnerability and decides to publish the vulnerability at a public network security forum in 8 weeks. Several days later, A receives a letter from B's attorney, forbidding him to disclose the vulnerability. A decides to move on and publishes his findings 8 weeks later. Now, A is facing the lawsuit. Would A win or lose the case? State your opinion. Please cite the related laws/regulations described in chapters 1 to 3 in the textbook to support your argument.

A would most likely lose the case. Although he did not violate the DMCA since he avoided reverse engineering and did not breach the CFAA because his random testing did not constitute unauthorized access, he ignored the legal notice from Company B's attorney and published the vulnerability. This likely violates the software license agreement and could be treated as a breach of contract or disclosure of trade secrets. While A acted ethically at first by notifying the company, he failed to follow responsible disclosure norms (commonly allowing 90 days) and instead disclosed after only 8 weeks. Based on the laws and regulations discussed in Chapters 1–3 (CFAA, DMCA, and software license restrictions), the court would side with Company B despite A's good intentions.